



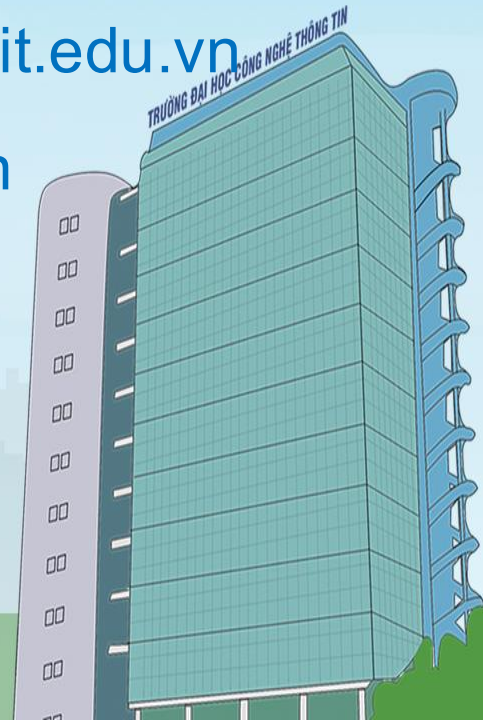
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN – ĐHQG-HCM
Khoa Mạng máy tính & Truyền thông

WEB APPLICATION FIREWALL

NT534 – An toàn mạng máy tính nâng cao

GV: Đỗ Thị Phương Uyên - uyendtp@uit.edu.vn

Nguyễn Duy – duyn@uit.edu.vn





Nội dung

Hôm nay học gì?

1. WAF là gì?
2. Tại sao chúng ta cần sử dụng WAF?
3. Kiến trúc Web Application
4. WAF ngăn chặn tấn công như thế nào?
5. Triển khai WAF

WAF là gì?

Định nghĩa

A web application firewall (or WAF) lọc, giám sát, và chặn lưu lượng truy cập HTTP/HTTPS đến và đi từ một ứng dụng web.

- Điểm khác biệt giữa WAF và tường lửa thông thường:
 - WAF có khả năng lọc nội dung của các ứng dụng web cụ thể. Ngăn chặn các cuộc tấn công xuất phát từ các lỗ hổng bảo mật của ứng dụng web.
 - Tường lửa thông thường đóng vai trò như một cổng bảo vệ giữa các máy chủ.



Tại sao chúng ta cần sử dụng WAF?

Các cuộc tấn công vào Web

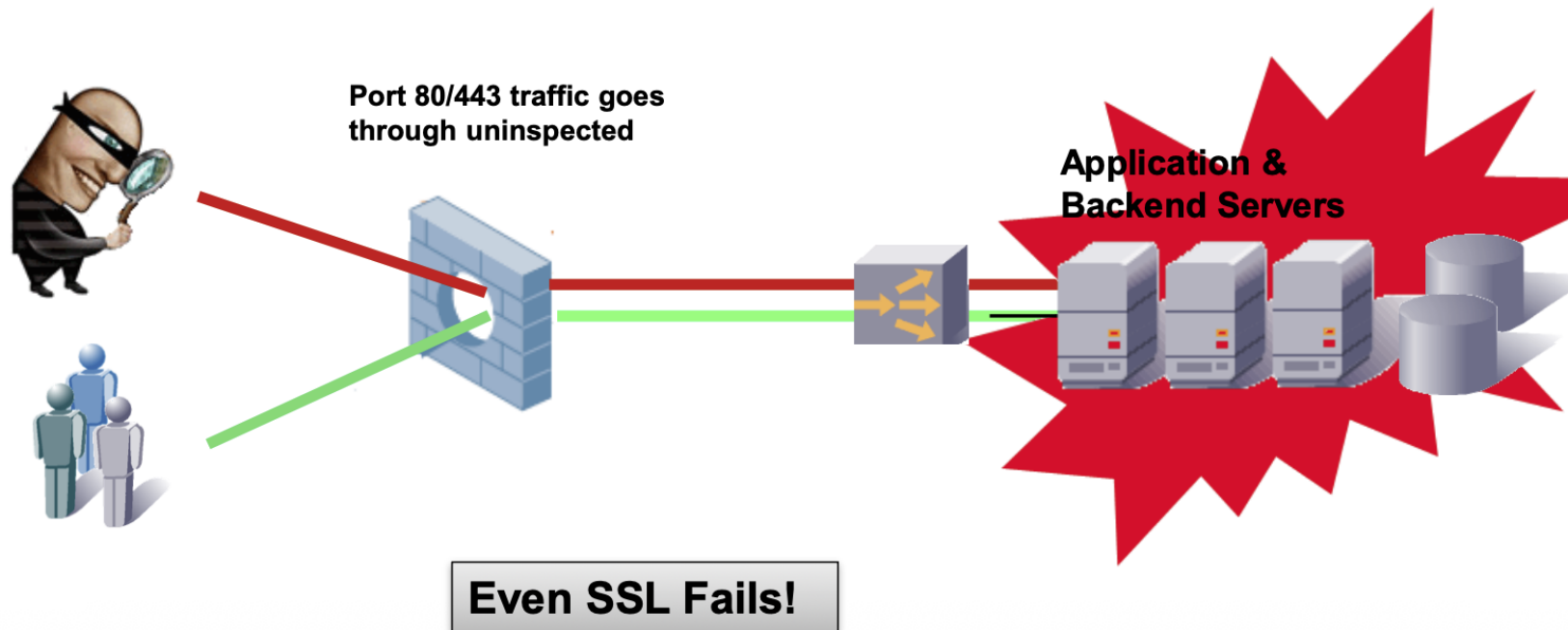
- Ứng dụng Web là mục tiêu chính của các hacker



Tại sao chúng ta cần sử dụng WAF?

Tại sao Network Firewalls thất bại?

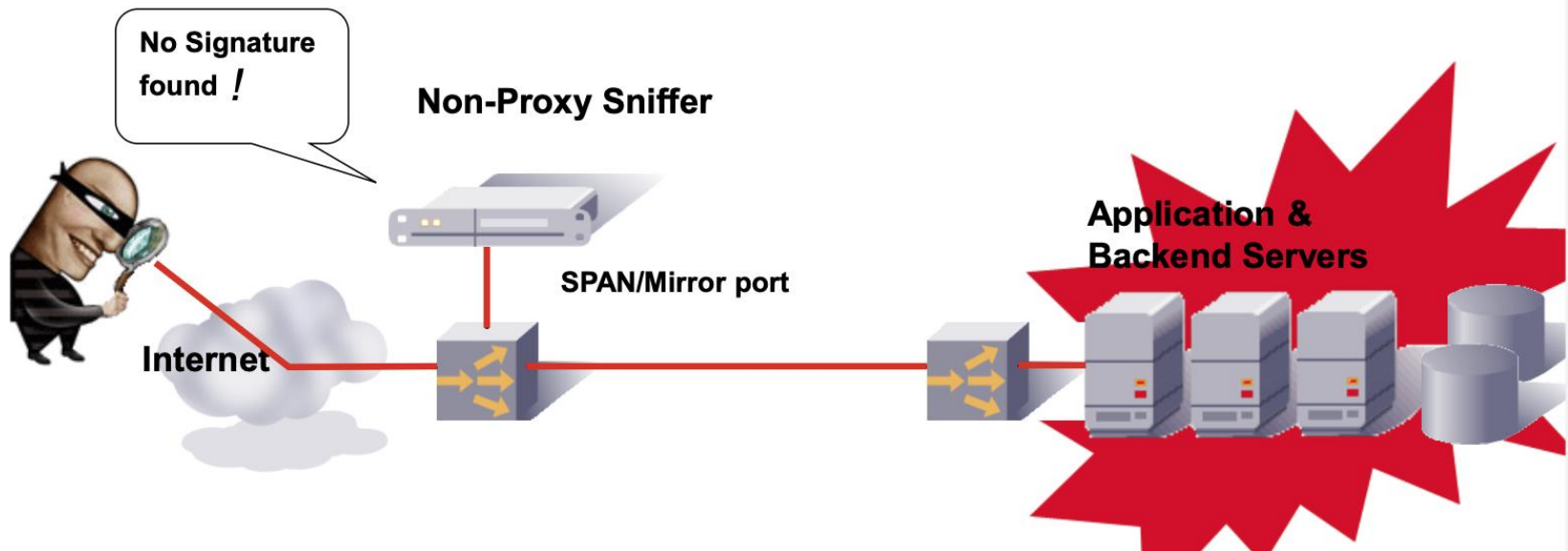
- Network Firewall truyền thống hoạt động ở Layer 3 - 4
- Không phân tích được payload ứng dụng
- Không phát hiện tấn công ẩn trong traffic hợp lệ



Tại sao chúng ta cần sử dụng WAF?

Tại sao IDPS truyền thống thất bại?

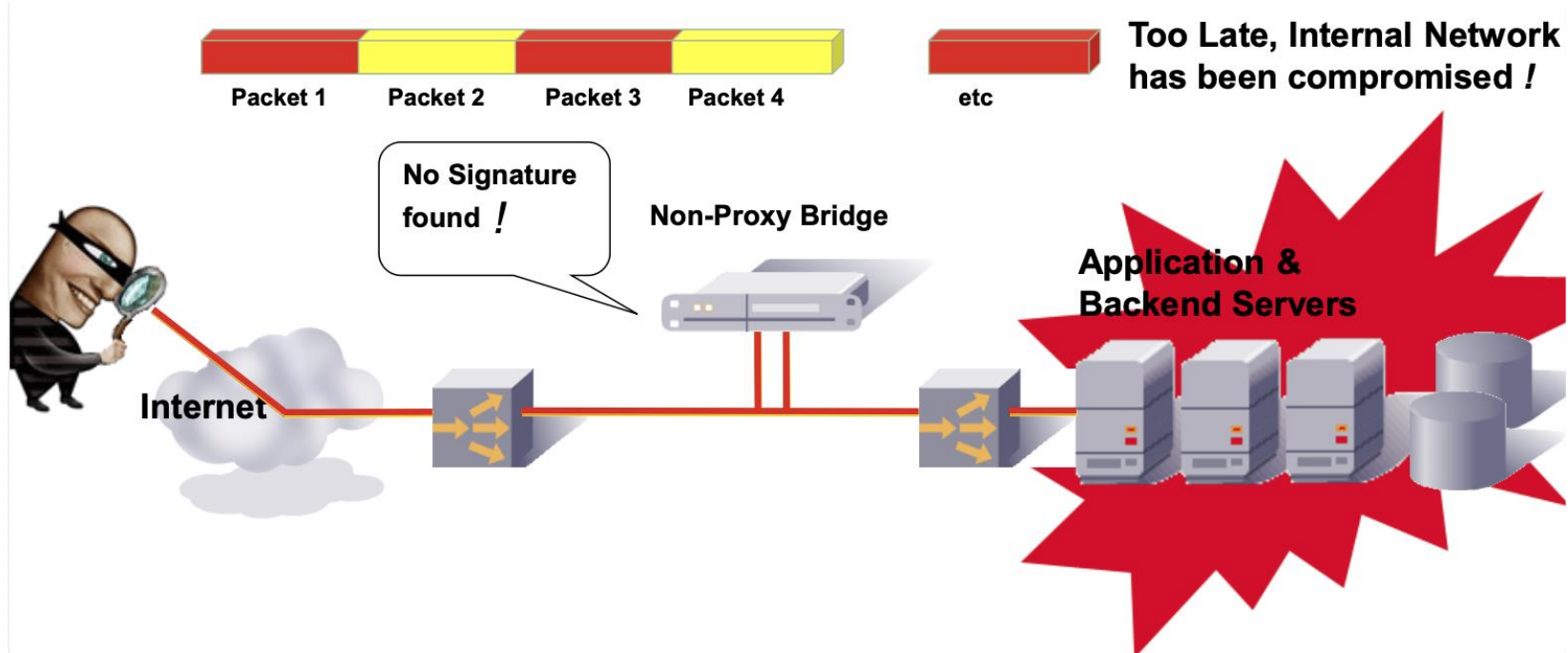
- Không hiểu ngữ cảnh ứng dụng
- Hạn chế khi xử lý HTTPS
- Dễ bị bypass bằng kỹ thuật mã hóa/obfuscation



Tại sao chúng ta cần sử dụng WAF?

Tại sao Non-Proxy Inline Bridge thất bại?

- Chỉ hoạt động ở chế độ bridge (transparent)
- Khả năng kiểm soát hạn chế

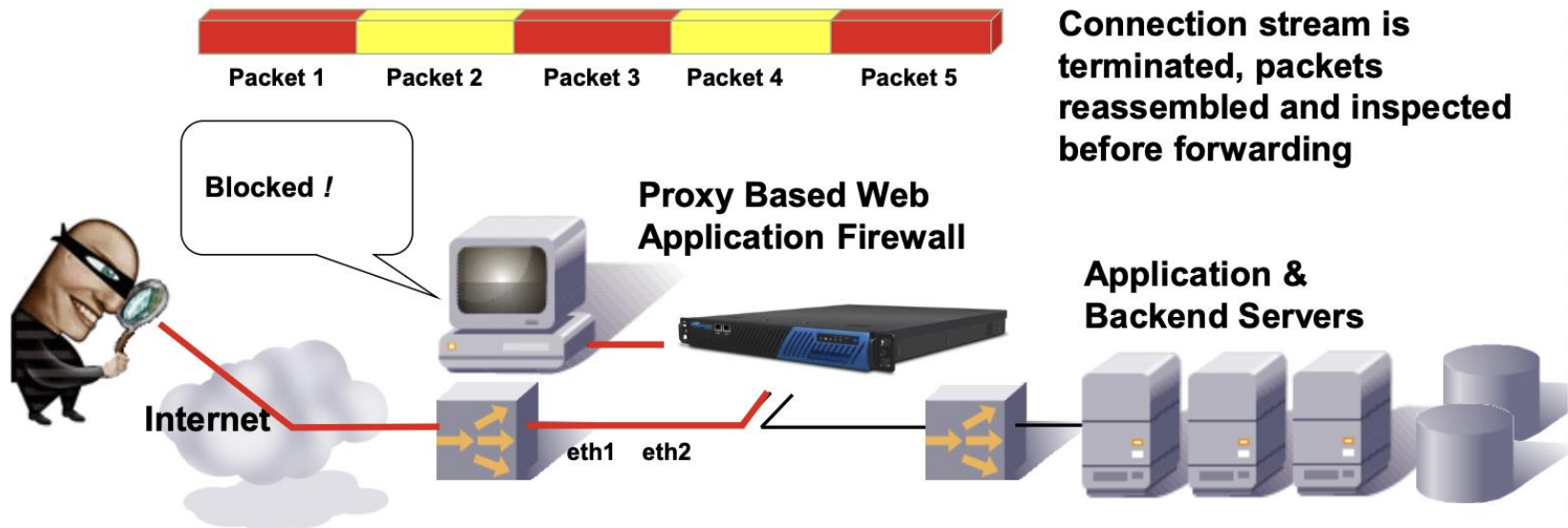


Tại sao chúng ta cần sử dụng WAF?

Tại sao Application Firewall Proxies đáp ứng nhu cầu?

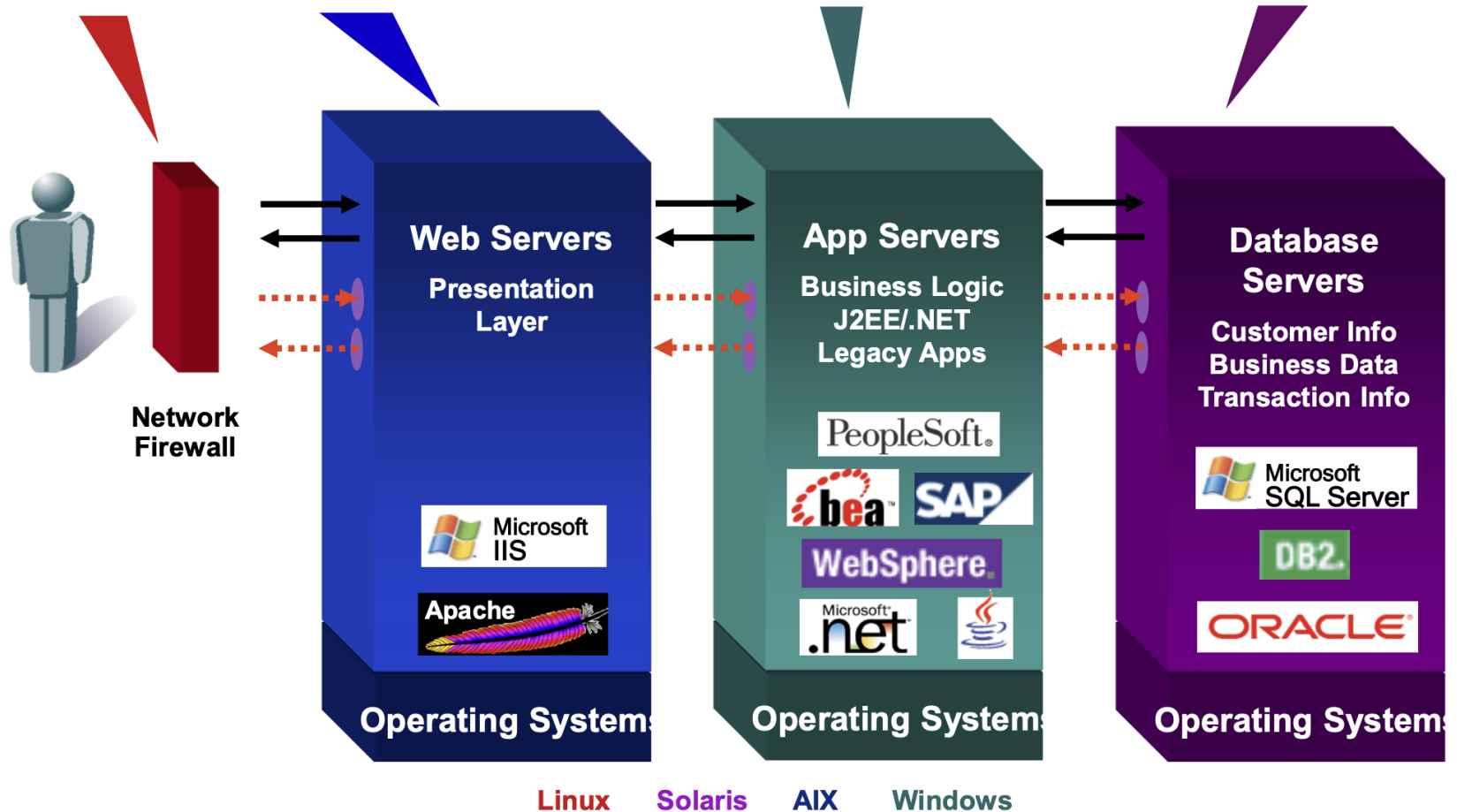
Application Firewall Proxy (Reverse Proxy WAF) hoạt động như **proxy trung gian**:

- Nhận request từ client
- Áp dụng rule/policy
- Terminate SSL
- Forward request hợp lệ đến server
- Phân tích nội dung HTTP



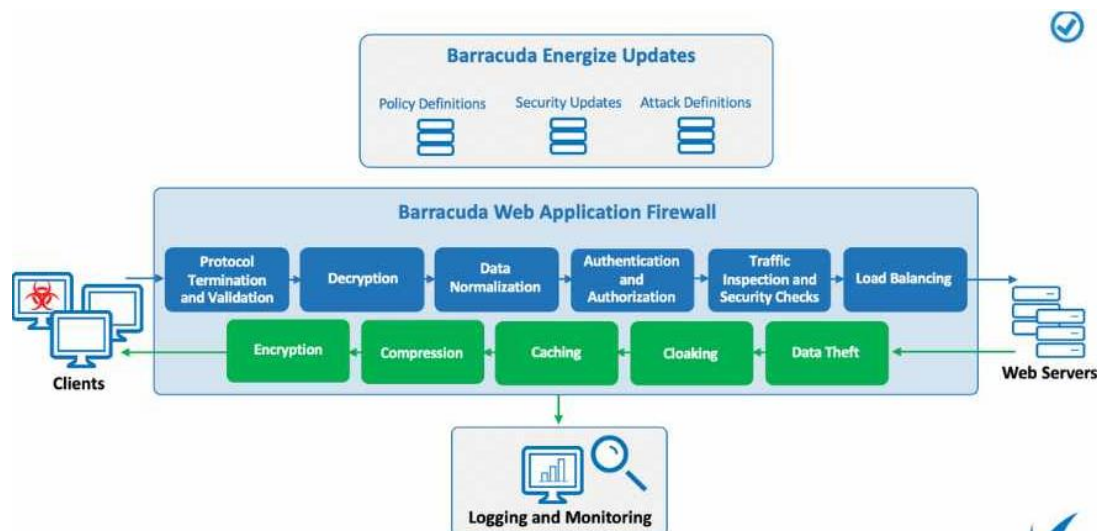
Kiến trúc Web Application

http ://www.none.to/script ?submenu=update&uid =1'+or+like'%25admin%25';--%00



WAF ngăn chặn tấn công như thế nào?

- Protocol Termination & Decryption
- Data Normalization & Validation
- Authentication, Authorization & Security Inspection
- Traffic Control & Optimization
- Logging, Monitoring & Continuous Updates



Triển khai WAF

Reverse Proxy

- WAF đóng vai trò là proxy cho máy chủ ứng dụng, đứng giữa client và Web Server.

- Đặc điểm:

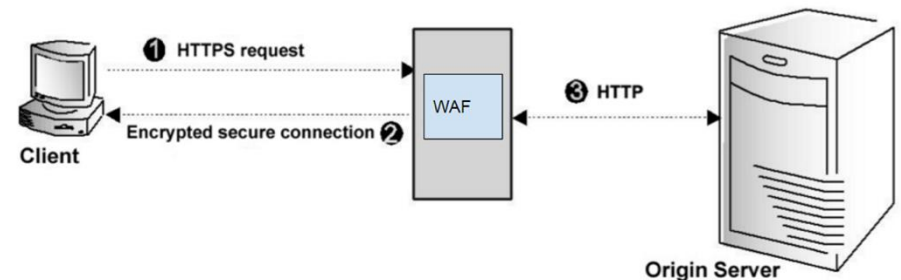
- Hoạt động ở Layer 7
- Thường yêu cầu thay đổi DNS trỏ về WAF
- Có thể terminate SSL/ TLS tại WAF

- Ưu điểm:

- Kiểm soát sâu nội dung HTTP
- Dễ tích hợp LB

- Nhược điểm:

- Phải thay đổi kiến trúc (DNS/IP)
- Có thể trở thành điểm nghẽn



Triển khai WAF

Transparent Proxy

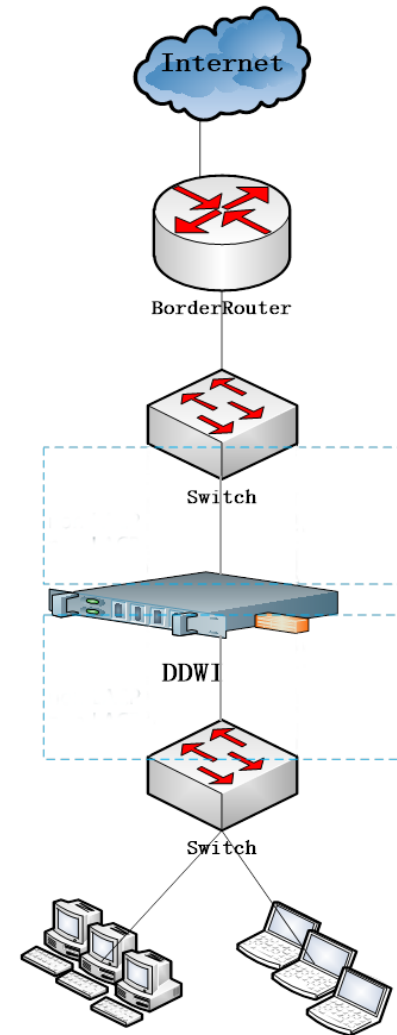
- Hoạt động như proxy nhưng **không yêu cầu thay đổi cấu hình client, không có IP riêng.**
- Có thể inspect sâu nếu terminate SSL
- Hoạt động ở Layer 3/4.
- Ưu điểm:
 - Không cần thay đổi cấu hình client
 - Triển khai linh hoạt
- Nhược điểm:
 - Inline mode, có thể thành điểm nghẽn khi gặp lỗi
 - Phức tạp khi xử lý SSL inspection



Triển khai WAF

Transparent Bridge

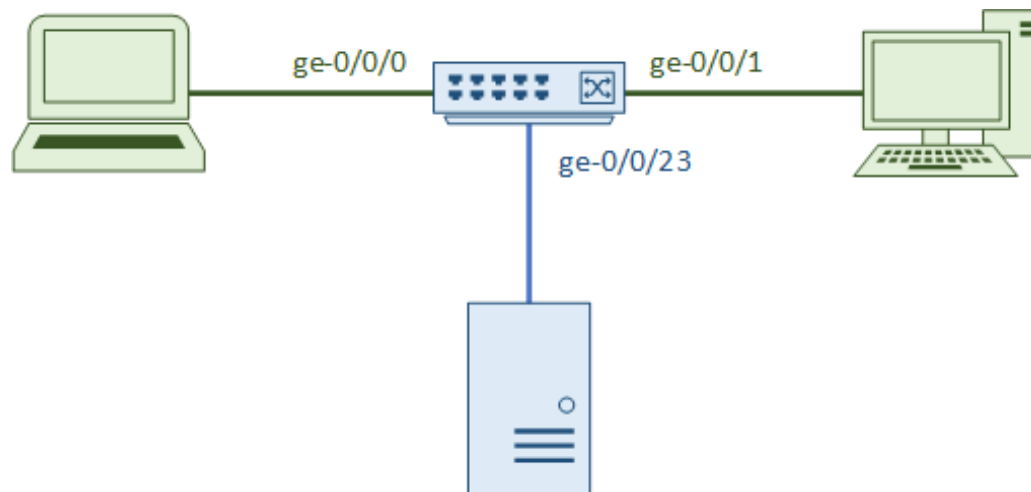
- Tương tự Transparent Proxy nhưng không tham gia vào kết nối TCP, không thay đổi các trường dữ liệu.
- Khả năng kiểm soát hạn chế hơn proxy
- Hoạt động như một bridge L2
- Ưu điểm:
 - Triển khai nhanh, ít thay đổi cấu hình mạng
 - Độ trễ thấp
- Nhược điểm:
 - Rủi do downtime
 - Ít linh hoạt hơn



Triển khai WAF

Traffic Mirroring

- Sao chép traffic từ SPAN/ TAP port
- Không chặn trực tiếp gói tin
- Chủ yếu dùng để giám sát mạng



Tóm tắt

Cần nhớ

- WAF là gì? Khác gì firewall truyền thống?
- Tại sao chúng ta cần sử dụng WAF?
- Cách WAF hoạt động
- Các cách triển khai WAF



Câu hỏi/thắc mắc nếu có?

Giới thiệu môn học



Today end,
See you
next week!

